sabsa-breb.tex

ARQUITECTURA DE SEGURIDAD SABSA PARA PAGOS INMEDIATOS BRE-B

NovaPay S.A. // Gerencia de Pagos Inmediatos (Bre-B)

```
$ ./sabsa --empresa novapay --area bre-b
> capas contextual..component ...... ok
> matriz SABSA (xlsx) ............. ok
```


> equipo

Sergio Andrés Caceres Díaz
Over Haider Castrillón Valencia
Michael Steven Pinilla Mateus

Universidad del Rosario

MISIÓN DE LA EMPRESA

Universidad del Rosario

$ cat /etc/novapay/mision

> mision.txt

Facilitar que personas y comercios en Colombia muevan su dinero de forma **inmediata**, **segura** y **sin costo** desde el celular, protegiendo la **confianza** de los clientes como el activo principal de la compañía.

Quiénes: NovaPay S.A., compañía de financiamiento digital vigilada por la SFC.

Qué: Cuentas digitales, transferencias y pagos QR por Bre-B.

Por qué: Bre-B es interoperable, 24/7 y gratuito, una oportunidad para captar a quienes usan efectivo.

OBJETIVO DEL ÁREA: PAGOS INMEDIATOS BRE-B

> objetivo --area bre-b

Operar las transferencias y pagos inmediatos de NovaPay S.A. sobre Bre-B (**24/7**, liquidación en **menos de 20 s**), administrando las llaves de los clientes ante el Directorio Centralizado (DICE) y la liquidación en el MOL del Banco de la República, con fraude y disponibilidad dentro de los umbrales de la Junta.

alcance

- Inscripción y portabilidad de llaves (celular, cédula, correo, alfanumérica).
- Envío, recepción y pagos QR a comercios.
- Conciliación con el MOL, disputas y fraude.

metas (KPI)

- Disponibilidad $\geq$ 99,95 % mensual.
- Transacción extremo a extremo $<$ 20 s.
- Fraude $<$ 5 pb del valor transado.
- Cero incidentes de fuga de datos personales.

$ sabsa --layer contextual --view business --owner "Junta, CEO, VP Pagos, CISO"

WHAT — activos

- Servicio 24/7 y $<$ 20 s.
- Fondos y datos de clientes.
- Reputación y confianza.

WHY — amenazas

- Fraude APP, ATO (SIM swap, phishing), mulas.
- DDoS y caída de nube o enlace.
- Insiders, supply chain, ransomware.

HOW — procesos

- Onboarding / KYC.
- Gestión de llaves ante el DICE.
- Envío, recepción, QR, conciliación.

WHO — organización

- Junta, CEO, VP Pagos, CISO.
- Fraude, Riesgos (SARO), Datos.
- BanRep, nube, biometría, telcos.

WHERE — sitios

- Bogotá: operación y SOC.
- Nube: región principal + alterna.
- Enlace dedicado a BanRep.

WHEN — tiempo

- Sin ventana de cierre.
- Picos 5× en quincena y primas.
- Reporte de incidentes a la SFC.

[SFC CE 007/2018 (hoy en la CBJ, CE 006/2025) · BanRep CRE DSP-465/2025]

Universidad del Rosario

$ sabsa --layer conceptual --view architect --owner "CISO"

WHAT — atributos

> Disponible, confidencial, íntegro.
> Autenticado, no repudiable.
> Resistente al fraude, cumplido.

WHY — control

> Sin MFA + dispositivo, no hay pago.
> Todo pago pasa por scoring.
> Cifrado con llaves en HSM.

HOW — estrategias

> **Zero Trust**.
> Defensa en profundidad.
> Privacy by design, DevSecOps.

WHO — dueños

> Proceso: VP Pagos.
> Riesgo ciber: CISO; fraude: Gte.
> Custodios: Plataforma y Datos.

WHERE — dominios

> Cliente · Exposición (DMZ).
> Core de pagos · Datos sensibles.
> Interbancario · Gestión.

WHEN — riesgo

> NIST CSF 2.0 + SARO.
> Revisión trimestral.
> KRI: fraude, MTTD, MTTR.

[ISO/IEC 27001:2022 · NIST CSF 2.0]

Universidad del Rosario

$ sabsa --layer logical --view designer --owner "Arquitecto de Seguridad"

WHAT — información

- Cliente, KYC, biometría.
- Llave ↔ cuenta (DICE).
- Transacciones, secretos, logs.

WHY — políticas

- MFA fuerte y límites por riesgo.
- Bloqueo 24 h tras cambio de SIM.
- TLS 1.3, mTLS y AES-256.

HOW — servicios

- CIAM y autorización central.
- Scoring de fraude en línea.
- Cripto, monitoreo y auditoría.

WHO — confianza

- Cliente: solo sus llaves.
- Agente: datos enmascarados.
- Ingeniero: just-in-time.

WHERE — flujos

- Cliente → API GW + WAF.
- Core → datos: solo servicio.
- Core → BanRep: mTLS dedicado.

WHEN — vigencias

- Sesión 5 min; token 10 min.
- Scoring < 300 ms.
- Certificados cada 90 días.

Universidad del Rosario

$ sabsa --layer physical --view builder --owner "Dir. Plataforma Cloud"

WHAT — datos

- Restringido: tokenizado.
- Confidencial: cifrado.
- Catálogo con dueño y retención.

WHY — reglas

- Reglas de fraude (velocidad, mula).
- Playbooks ATO, DDoS, ransomware.
- Parches críticos en 7 días.

HOW — mecanismos

- Passkeys FIDO2 + device binding.
- WAF, anti-DDoS, service mesh.
- HSM/KMS, tokenización, SIEM.

WHO — acceso

- SSO + llave FIDO2 interna.
- RBAC + ABAC (monto, horario).
- PAM con sesiones grabadas.

WHERE — red

- VPC por ambiente.
- Subred por dominio.
- 3 zonas + región alterna.

WHEN — tiempos

- **RTO 15 min, RPO 0.**
- Failover de zona < 1 min.
- Backups inmutables diarios.

$ sabsa --layer component --view tradesman --owner "Líder SecOps"

WHAT — plataforma

- Amazon EKS, Aurora, MSK.
- AWS CloudHSM y KMS.
- HashiCorp Vault.

WHY — riesgo

- Feedzai (fraude, ML).
- Microsoft Sentinel (SIEM/SOAR).
- Tenable, Snyk, Security Hub.

HOW — protocolos

- ISO 20022, OIDC, WebAuthn.
- Cloudflare, Istio (mTLS).
- CI: Semgrep, Trivy, ZAP.

WHO — identidades

- Clientes: Auth0 / Keycloak.
- Empleados: Entra ID + YubiKey.
- PAM: CyberArk / Teleport.

WHERE — nodos

- EKS prod (3 AZ) + DR.
- Sin IP pública en core/datos.
- Direct Connect a BanRep.

WHEN — agenda

- Pentest trimestral.
- Escaneo semanal y por build.
- DRP semestral; NTP en todo.

- **Trazabilidad:** Cada producto de la capa Component se justifica hacia arriba hasta un requisito de negocio de Bre-B, de forma que ningún control queda sin dueño ni sin motivo.
- **Fraude antes que intrusión:** En pagos inmediatos el dinero no se puede reversar, por lo cual la autenticación fuerte, el device binding y el scoring en línea pesan tanto como el perímetro.
- **Disponibilidad como requisito de seguridad:** Un servicio 24/7 sin ventana de cierre obliga a diseñar la resiliencia (RTO 15 min, RPO 0) desde la capa conceptual y no como un añadido.
- **Cumplimiento integrado:** La SFC, el Banco de la República y la Ley 1581 se tratan como atributos de negocio y no como un checklist al final del proyecto.

SABSA = seguridad derivada del negocio, no agregada a la tecnología

$ sabsa --preguntas

¿PREGUNTAS?



NovaPay S.A. // Gerencia de Pagos Inmediatos (Bre-B)